

	INFORME PENTEST SOFTWARE **** (WEB)	FECHA DE ELABORACIÓN	Mayo /2026
--	--	---------------------------------	---------------

Exposición de Dirección IP en end-points de reportes anónimos

Introducción:

En este apartado adoptamos la perspectiva de un atacante con conocimientos técnicos en hacking. Aunque muchos usuarios de la plataforma no dominen estas técnicas, no debe subestimarse la posibilidad de que un actor malintencionado con experiencia pueda identificar información asociada a los usuarios que realizan reportes. Evaluar el hallazgo desde esta postura permite estimar el riesgo real y proponer contramedidas concretas y efectivas.

La plataforma ofrece un mecanismo destinado a realizar reportes de manera anónima. Sin embargo, durante el análisis de las peticiones realizadas al consultar el perfil de un reporte, se identificó que la respuesta proporcionada por el servidor incluye la dirección IP asociada al usuario que realizó dicho reporte. Esta información es enviada al cliente a través de los endpoints utilizados para cargar los datos del reporte, a pesar de que no resulta necesaria para la funcionalidad normal de visualización.

Adicionalmente, se identificó que la dirección IP también puede ser expuesta en los **comentarios asociados a los reportes**. De esta manera, la información de red del usuario no solamente queda expuesta al consultar los datos principales del reporte, sino que también puede aparecer asociada a las interacciones realizadas dentro de los comentarios.

La exposición de este dato representa una pérdida del anonimato ofrecido por la plataforma, ya que un usuario que consulte un reporte o sus comentarios puede acceder directamente a la dirección IP del supuesto reportante mediante la información proporcionada por el servidor.

¿Qué es la exposición de información sensible?

La exposición de información sensible ocurre cuando una aplicación revela datos que deberían permanecer restringidos, privados o innecesarios para el usuario que realiza una determinada acción. Este tipo de vulnerabilidad puede producirse cuando el servidor devuelve información adicional en respuestas HTTP, APIs o estructuras JSON que posteriormente no son mostradas directamente en la interfaz gráfica.

En este caso, la aplicación expone la dirección IP de usuarios que realizan reportes o participan mediante comentarios dentro de un sistema presentado como anónimo. Aunque

	INFORME PENTEST SOFTWARE **** (WEB)	FECHA DE ELABORACIÓN	Mayo /2026
--	--	---------------------------------	---------------

la dirección IP no constituye necesariamente una identificación directa de una persona por sí sola, puede utilizarse como información auxiliar para correlacionar actividades, identificar una conexión de origen aproximada o realizar otras técnicas de reconocimiento.

Más información en: [CWE-200: Exposure of Sensitive Information to an Unauthorized Actor | MITRE](#)

Una de las consecuencias inmediatas de esta vulnerabilidad es la pérdida del anonimato del usuario, permitiendo potencialmente:

- Obtener la dirección IP asociada al usuario que realizó un reporte anónimo.
- Obtener la dirección IP asociada a usuarios que participan mediante comentarios.
- Correlacionar una dirección IP con diferentes reportes o comentarios realizados dentro de la plataforma.
- Obtener información geográfica aproximada asociada a la dirección IP mediante servicios externos.
- Realizar actividades de reconocimiento sobre la dirección IP expuesta.
- Identificar o reducir el anonimato de usuarios que razonablemente esperaban que su identidad permaneciera oculta.
- Acceder a esta información mediante endpoints accesibles para usuarios no privilegiados, sin necesidad de contar con permisos administrativos.

	INFORME PENTEST SOFTWARE **** (WEB)	FECHA DE ELABORACIÓN	Mayo /2026
--	--	---------------------------------	---------------

Evidencias

Perfil “Anónimo”

Ubicación

Departamento:

Distrito:

Información Personal

Edad: 22

Ocupación: Un chico que puede parecer lindo en un comienzo, carismático, sociable y hablador pero no confíen ch

Detalles de la Infidelidad

Tiempo de relación: 3

Periodo de infidelidad: 2 y medio

```
{
  "record": {
    "nombres": ,
    "apellidos": ,
    "departamento": ,
    "distrito": ,
    "edad": 22,
    "ocupacion": "Un chico que puede parecer lindo en un comienzo, carismático, sociable y",
    "ets": "Sí",
    "tiempoRelacion": "3",
    "periodoInfidelidad": "2 y medio",
    "datosAdicionales": "Este chico mientras estaba con migo me engaño muchas veces con m",
    "pruebas": [],
    "id": "rec_1764653496447_hsy6a2pz",
    "creatorId": "user_1764651419842_bdfqmesgl",
    "createdAt": 1764653488892,
    "descripcion": "Este chico mientras estaba con migo me engaño muchas veces con muchas",
    "country": "PE",
    "creatorIP": "179."
  }
}
```

	INFORME PENTEST SOFTWARE **** (WEB)	FECHA DE ELABORACIÓN	Mayo /2026
--	--	---------------------------------	---------------

Incluso como se mencionó anteriormente no solo en publicaciones sino también en comentarios.

Comentario “Anónimo”

Anónimo

30/11/2025

Y también que es un tema muy sensible fue cuando el me pidió fotos por primera vez y yo tengo un trauma grande con eso y se lo comenté pero le valio tres hectáreas de pene y siguió insistiendo muchas veces a pesar de lo que le comentaba sobre mis miedos, siempre le decía que no y no pero siempre insistía o me decía que me amaba mucho demasiado y que solo quiere verme

```
"comments": [  
  {  
    "id": "1764518845177_ev52wgypc",  
    "userId": "user_1764518300491_mie2vtgca",  
    "fingerprint": "8164b4492025c2e0ef3c35c516829e676f0b8973241482e6d41ae3851a628c59",  
    "ip": "179. ",  
    "text": "También hay otras pequeñas cosas que él hizo como que tenía todavía cosas",  
    "proofs": [],  
    "timestamp": 1764518845177  
  },  
]
```

	INFORME PENTEST SOFTWARE **** (WEB)	FECHA DE ELABORACIÓN	Mayo /2026
--	--	---------------------------------	---------------

Medida correctiva:

Se recomienda modificar la lógica de los endpoints responsables de consultar y devolver la información de los reportes y comentarios, evitando incluir la dirección IP del usuario en las respuestas destinadas al cliente. La dirección IP debe tratarse como información sensible y no debe exponerse a usuarios no autorizados, especialmente cuando la funcionalidad se presenta como anónima.

Como medida principal, el servidor debe aplicar el principio de mínimo privilegio y minimización de datos, retornando únicamente los campos estrictamente necesarios para el funcionamiento de la aplicación. Los atributos relacionados con la dirección IP deben eliminarse de las respuestas JSON destinadas a usuarios finales.

Adicionalmente, se recomienda:

- Eliminar el campo de dirección IP de las respuestas de los endpoints de reportes y comentarios.
- Verificar que ningún endpoint relacionado exponga indirectamente la IP mediante otros campos o estructuras JSON.
- Mantener las direcciones IP únicamente cuando sean necesarias para funciones internas de seguridad, auditoría o prevención de abuso.
- Restringir el acceso a cualquier información de red almacenada mediante controles de autorización adecuados.
- Revisar los demás endpoints de la aplicación para identificar posibles exposiciones similares de información sensible.
- Realizar pruebas de regresión después de aplicar la corrección para confirmar que la IP ya no sea accesible desde el cliente.